以太坊中的网络通信与交易安全

冯雁霞, 刘小慧, 钟珊珊, 田晨阳
中山大学计算机学院, 广州, 中国
{fengyx8,liuxh65,zhongshsh5,tianchy6}@mail2.sysu.edu.cn

ABSTRACT

本文聚焦区块链以太坊技术中的网络安全前沿问题，包括网络安全、通信安全与交易安全三方面。我们介绍了区块链与以太坊 P2P 网络的背景，结合最新研究与应用阐述了以太坊中节点网络的构建，论述了节点加密通信、用户交易验证的方案与过程，并基于此提出我们的思考。

1 引言

区块链技术起源于 2008 年由“中本聪”在密码学邮件发表的论文《比特币：一种点对点电子现金系统》[1]。区块链是指一种电子记录形式的账簿，其中每一个区块是账簿的一页，从第一页“链接”到最新一页。这些区块一旦被确认，几乎不能做修改操作，每个区块包含了当前一段时间内的所有交易信息和区块元数据，构架如图 1所示。

“中本聪”在其比特币白皮书中非常详细地介绍了区块链系统的建立过程 [1]: 1) 交易节点将新生成的交易数据向全网所有节点进行广播; 2) 每个节点都将收集到的交易数据存储到一个区块中; 3) 每个节点基于自身算力在区块中找到一个具有足够难度的工作量证明; 4) 当某个节点找到区块的工作量证明后，就向全网所有节点广播此区块; 5) 仅当包含在区块中的所有交易都是有效的且之前未存在过的，其他节点才认同该区块的有效性; 6) 其他节点接受该数据区块，并在该区块的末尾制造新的区块以延长该链条，而将被接受区块的随机哈希值视为先于新区块的随机哈希值。

区块链系统的节点具有分布式、自治性、开放可自由进出等特性，因而一般采用 P2P 网络来组织散布全球的参与数据验证和记账的节点。P2P 网络中的

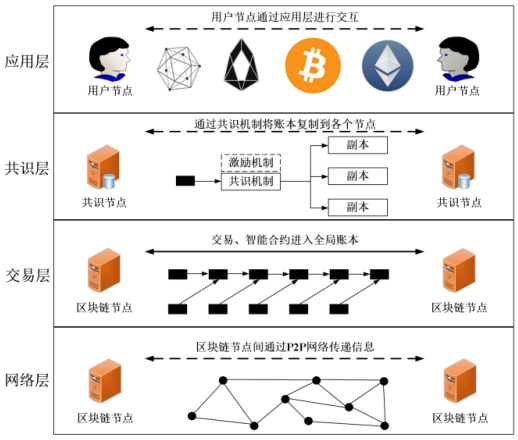

Figure 1: 区块链构架图

每个节点地位对等，均会承担网络路由、验证区块数据、传播区块数据、发现新节点等功能。

以太坊是一个开源的有智能合约功能的公共区块链平台。以太坊的 P2P 网络主要有两部分构成：节点之间互相广播用于节点发现的 UDP 网络和节点之间互相连接用于传输数据的 TCP 网络。Kademlia 协议基于 UDP，通过构建节点路由表，实现节点发现和资源定位。RLPx 协议基于 TCP，通过创建 TCP 连接并确定一对临时密钥，实现节点进行通信加密，而 ECDH 密钥交换算法则是实现通信双方共享密钥的基础。此外，节点通信还涉及通信双方协议版本协商的过程。

EC 曲线密码不仅可以应用于通信双方加密环节，还可以应用于用户交易验证环节。以太坊是以交易为基础的状态转移系统，主要使用 ECDSA 数字签名与验证来确保交易的不可伪造。ECDSA 算法基于 EC 曲线离散对数问题的难解性，有两方面安全性的考虑：一是在已知公钥的情况下，无法推导出该公钥对应的

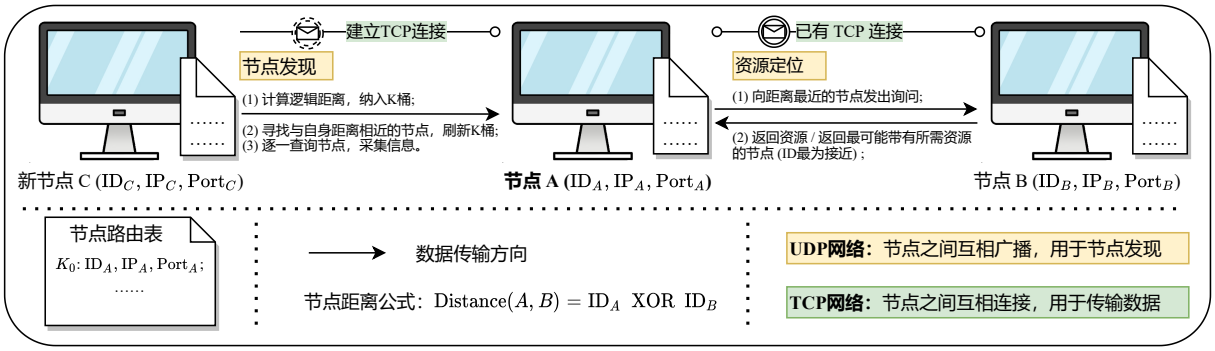

Figure 2: 基于 Kademlia 协议的 P2P 网络基本结构

私钥；二是证明某人拥有一个公钥所对应的私钥的过程中不会暴露关于私钥的任何信息。近年来，针对签名验证效率有很多提升的方案，比如：聚合签名、批验证、组测试等等。

本文系统地梳理了以太坊加密的基本原理、核心技术、典型应用和前沿研究，以期为未来研究提供有益的启发和思考。本文组织结构为：第 1 节概述区块链的运作机制；第 2 节阐述以太坊节点网络构建；第 3 节阐述以太坊节点通信加密；第 4 节阐述以太坊用户交易验证；第 5 节总结本文内容并提出思考。

2 以太坊节点网络构建

基于分布式账本之上的区块链网络，采用 P2P 网络将所有节点连接在一起，设计共识机制使无信任基础的双方在不需要第三方的情况下建立互信，使用广播的方式传播交易信息，加上激励机制来保证节点提供算力以维持整个网络的顺利运行 [27]。现有研究提出分布式哈希表 (distributed hash table, DHT) 来解决 P2P 网络节点的相互发现及网络成型的过程易遭受攻击的问题 [29]，参与到 DHT 的节点可以很轻松地检索到某个键对应的值。Kademlia 是研究者在 2002 年提出的 DHT 协议 [12]，被应用于以太坊中实现路由 [21]。

2.1 Kademlia 协议

Kademlia 协议中节点间可相互通信，无需中央控制器支持，多个节点构成分布式网络，网络中任意节点均可在网络中采集资源。在该协议基础上，各个 DHT 节点均由三项内容组成，即 IP 地址、端口与节点 ID，其节点 ID 是节点 IP 地址与端口经过 SHA-1 算法散列后得出，各个节点信息都会存储到路由表中，且任何 2 个节点之间的距离可通过节点 ID 的异来表示 [20]。基于 Kademlia 协议的 P2P 网络结构如图 2所示，Kademlia 协议属于 UDP 部分，通过构建节点路由表，在 TCP 的支持下实现节点发现和资源定位。

2.1.1 **节点路由表**. 在该协议中，各个节点在初始状态下被分配成一个 160 位的节点 ID，节点之间距离可通过计算得出，公式为:

$$\textbf{Distance}(A, B) = \mathrm{ID}_A \ \textbf{XOR} \ \mathrm{ID}_B, \tag{1}$$

式中，ID_A 与 ID_B 分别代表的是节点 A 和 B 的节点 ID，节点之间 ID 的异是长度为 160 的比特数组。节点之间逻辑距离计算可打破地域上的距离限制，使逻辑距离变得更加近。路由表由 K 桶列表构成，对于任一编号为 i 的桶而言，各个节点均存储到与自身相距 $2i$ 距离的节点信息中 [36]。

2.1.2 **自组织**. 该协议中的自组织包括节点加入与退出两项内容。对一个新节点来说，首次加入 Kademlia 网络应经以下流程。首先，获取一个网络内部节点信息，即引导节点，计算二者间的逻辑距离，将其纳入与之相对的 K 桶中；然后将请求发送到该节点中，由此寻找与自身距离相近的节点，最后使全部 K 桶被刷新。通过与自身距离由近到远节点的逐一查询，新节点采集的信息不断增加，在刷新 K 桶的同时，也将

自身信息留在了其他 K 桶中。节点在退出网络时无须发送任意信息，因为各个资源都会发布 K 个副本，因此不会对该节点所有资源产生负面影响。

2.1.3 **资源定位**. 对于任意资源来说，哈希长度为 160 比特数组，通过算法对资源与节点间的距离进行计算。在对特定资源进行查询时，可以以资源哈希为依，向与之距离最近的节点发出询问，判断其是否了解那些节点中带有所需资源，如若结果为“不知”，则返回到最可能知道谁拥有所需资源的节点列表中 [24]。

2.2 以太坊节点网络安全性

区块链由于其独特的链式结构和底层的 P2P 网络，其在安全性方面有独特优势，因此区块链在密钥分发、隐私数据保护等安全领域产生了较多理论成果 [4, 18]。另一方面，由于其去中心的分布式架构和公有链无准入要求的特点，区块链在安全方面也存在劣势。近年来大量研究致力于提升 P2P 网络的安全性，深度学习也被广泛应用于 P2P 网络的安全性检测当中。

2.2.1 **节点网络安全性优势**. P2P 网络节点物理位置分散，每一个节点大都同时具有信息消费者、信息提供者和信息通讯等三方面的功能。公私钥都是节点自己生成，不需要中心化的服务器存储，与攻击中心化服务器相比，黑客很难通过攻击某一个节点获得大量用户信息，从而更改全局账本。

2.2.2 **节点网络安全性劣势**. P2P 网络节点准入要求极低，与专业服务器相比安全漏洞多防护能力差，黑客很容易针对少量关键节点发起网络路由攻击或者直接入侵，通过日蚀攻击 [10] 和路由攻击等获得利益。黑客利用一个节点的出度受限可以用日蚀攻击将节点从主网中隔离，出度越多、节点随机化链接程度越高，黑客的攻击难度就越大。网络协议的好坏通常决定了信息流转的能力，由于 P2P 网络结构不同，以太坊就远比比特币更容易受到日蚀攻击的影响 [2, 21]。

2.2.3 **节点网络安全性问题应对机制**. 近几年，深度学习被应用于检测 P2P 网络安全。针对 P2P 僵尸网络检测，林宏刚等 [26] 提出一种基于图神经网络的 P2P 僵尸网络节点交互特征及网络拓扑结构信息实现检测，邹福泰等 [33] 基于生成对抗网络生成僵尸网络特征样本，这些方法有效提高 P2P 僵尸网络检测能力和泛化能力，降低误报率。针对 P2P 网络流量异常问题，张龙等 [19] 提出基于深度学习的流量分类与异常检测方法。从深度学习在 P2P 网络的应用上看，深度学习往往用于检测 P2P 网络是否遭受攻击，是一种有效的监督机制，但无法从根本上提高 P2P 网络安全性。

为了从根本上提高节点网络安全性，防止网络层攻击，高镇等 [37] 在以太坊源码的基础上加入了二次验证与数据恢复过程。为了更好地研究僵尸网络威胁，全分布式非结构化拓扑网络虽然在组织结构不如全分布式结构化拓扑网络利于管理，但是由于进入网络更随机，黑客预先生成节点隔离目标节点的成本要更大，赵昊等 [30] 采用分层混合拓扑结构，在僵尸子网层构建基于智能合约的命令传输通道，建立可信度评价机制判断节点真实性，从流量和终端两大层面增强网络的对抗性。张等 [16] 提出了 HE-AES 加密算法，实现数据的分布式存储和自动恢复。Maeng 等 [11] 提出节点发现机制，用于降低网络遭受攻击的可能。此外，为防止权力的过度集中，可以设计防 ASIC 挖矿的共识协议，也可以用密码抽签技术增加共识层数 [21]。

3 以太坊节点加密通信

以太坊中的节点，需要将新生成的交易数据或新区块向全网所有节点进行广播，这就涉及到了以太坊节点通信问题。以太坊 P2P 网络的通信由一组网络协议组成，名为 devp2p [7]。devp2p 包括节点发现协议和 RLPx 传输协议，分别基于 UDP 和 TCP，如图 3 (a) 所示 [5]。以太坊 P2P 网络中的节点使用 RLPx 协议进行通信加密，并基于 ECDH 算法进行密钥交换。基于此，本章首先介绍 RLPx 协议与 ECDH 算法，然后分析梳理以太坊节点的加密通信过程。

3.1 RLPx 协议

RLPx（Recursive Length Prefix eXtension）协议是一种基于 TCP 的传输协议，用于以太坊节点之间的通信。RLPx 连接通过创建 TCP 连接并同意一对临时密钥来建立，从而保障以太坊节点之间能够传输加密的、序列化的数据 [5]。值得注意的是，虽然 RLPx 是专门为以太坊开发的，但它也支持其他上层应用程序。不同的应用程序在 RLPx 的 Hello 报文中表示为不同的“能力”(capabilities)[9] 在 RLPx 中，两个节点在传输重要消息之前需要执行两阶段握手来初始化会话，图 3（b）展示了两次握手的概况：第一次握手时，两节点进行公钥交换，使后续的通信消息得到加密和身份认证。通信的“发起者”（initiator）生成带有共享秘密的临时密钥，并向“接受者”（recipient）发送包含共享秘密的认证信息（auth）；接收者解密并生成与共享密钥相同的密钥，然后向发起者响应一个确认消息（auth-ack）。在协商好临时密钥后，连接双方发送“Hello 报文”或“断开连接”消息，这被认为是第二次握手。“断开连接”消息通知对方节点即将断开连接，并可在消息中追加一个字节的原因代码；或者，两个节点通过交换 Hello 报文来详细说明彼此的客户端信息，包括 RLPx 协议的版本号、客户端 ID、支持的“能力”、监听端口，以及节点 ID 等 [9]。

基于 RlPx 协议，以太坊在不同客户端条件下使用不同“能力”，主要有三种：ETH(Ethereum Wire Protocol)、LES（Light Ethereum Subprotocol）和 PIP（Parity Light Protocol）。其中，ETH 协议使用最为广泛，用于“全节点”（Full Nodes）之间交换区块链信息；LES 协议和 PIP 协议主要用于“轻节点”（Light Nodes），轻节点不参与 P2P 网络的构建，它只下载区块头并根据需要获取区块链的其他部分 [9]。

3.2 ECDH 算法

3.2.1 ECDH **算法基础**. 以太坊节点的加密通信过程基于 ECDH（Elliptic Curve Diffie-Hellman）密钥交换算法，该算法是 Diffie-Hellman 密钥交换协议在椭圆曲线（Elliptic Curve）上的离散对数实现 [28]。通过 ECDH 算法，通信双方（设为节点 A 和 B）可以使用自己的私钥和对方的公钥计算出一个共享密钥，即 ECDH（A 私钥，B 公钥）= ECDH（B 私钥，A 公钥）。图 4展示了两个节点使用 ECDH 算法进行密钥交换的过程，具体流程如下：

（1）通信双方在通信前选择并公开一组系统参数（q，F_q，E，G，n），其中，p 为大素数，有限域为 F_q，其上的安全椭圆曲线群为 E，以及某个阶为大素数 n 的基点 $G \in E(F_q)$[3]。

（2）节点 A 随机产生一个正整数 $k_A \in [1, n-1]$ 作为自己的私钥，并计算出 A 的公钥 $Q_A = k_A \times G$，发送给节点 B；

（3）节点 B 随机产生一个正整数 $k_B \in [1, n-1]$ 作为自己的私钥，并计算出 B 的公钥 $Q_B = k_B \times G$，发送给节点 A；

（4）节点 A 收到了节点 B 发来的 Q_B 后，计算 $K_{AB} = k_A \times Q_B = k_A \times k_B \times G$；

（5）节点 B 收到了节点 A 发来的 Q_A 后，计算 $K_{BA} = k_B \times Q_A = k_B \times k_A \times G = k_A \times k_B \times G$；

（6）于是，通信双方就共享了会话密钥 $K = K_{AB} = K_{BA}$。其中，对于任意的整数 k，用 $k \times G$（简写为 kG）表示点 G 的数量乘法，它定义为 G 的连续 k 次加法。

根据椭圆曲线的特性，上述过程中的 G 是椭圆曲线 E 上的一点，称为基点（Generator Point），该点的横坐标和纵坐标值都很大：给定整数 k，计算点 $Q = k \times G$ 很容易；反之，给定点 Q，计算整数 k'，使得 $k' \times G = Q$ 却非常困难 [8]，我们只能依次计算 $1G$、$2G$、...、kG 的坐标，通过比较其值是否与 Q 相等，判断 k' 的取值，这在一定程度上保证了 ECDH 密钥交换算法的安全性。

3.2.2 ECDH **算法的优势与不足**. ECDH 密钥协商协议简单，易于实现，与 Diffie-Hellman 算法相比，在相同的安全强度下，ECDH 协议需要的密钥长度更小，具有更好的实现算法，易于软硬件实现，计算速度更快，处理能力要求更低，特别适用于计算能力、存储空间、带宽及功耗等受限的环境 [25]。但该协议不支持对协商密钥的认证功能，容易遭受中间人的攻击，

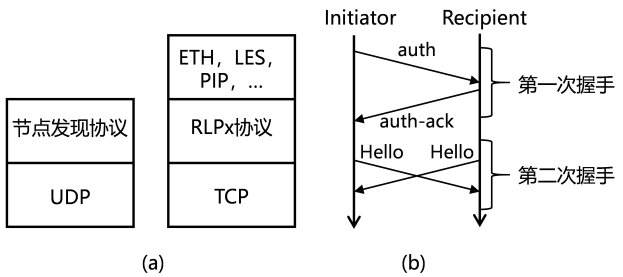

Figure 3: 以太坊网络中的 RLPx 传输协议

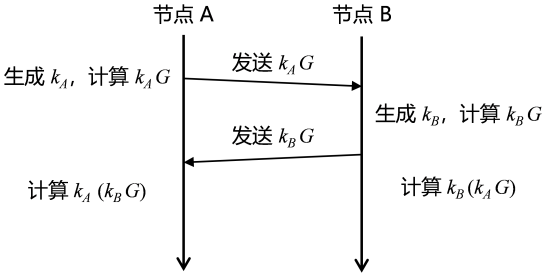

Figure 4: ECDH 密钥交换算法

存在不足 [8]。在上述过程中，基点 G 和通信双方的公钥 Q_A、Q_B 都是公开的：

（1）如果攻击者可以窃听，第三方可以从公开信道上截获消息 G、Q_A 和 Q_B，为了获得会话密钥 K_{AB}（或 K_{BA}），攻击者必须由 G、Q_A 和 Q_B 求出随机数 k_B 或 k_A，而这将面临椭圆曲线上的离散对数难题。

（2）攻击者可以选择一个大整数 $k_M \in [1, n-1]$，截获节点 A 发给 B 的 $k_A \times G$，节点 B 发给节点 A 的 $k_B \times G$，然后将 $k_A \times G$、$k_B \times G$ 篡改为 $k_M \times G$，分别发给节点 B 和 A。协商结束时，节点 A 与攻击者生成共享密钥 $k_A \times k_M \times G$，但 A 误以为是和节点 B 共享的；节点 B 与攻击者生成共享密钥 $k_B \times k_M \times G$，而 B 误以为是与节点 A 共享的，真正的通信节点 A 与 B 之间并没有共享一个密钥。当节点 A 发送机密信息给 B 时，A 用 $k_A \times k_M \times G$ 对消息加密，攻击者截获进行解密，然后伪造一个消息，用密钥 $k_B \times k_M \times G$ 加密后发送给 B，这样，攻击者成功地欺骗了节点 A 和 B，而节点 A 和 B 却不知情。

为此，部分学者对 ECDH 算法进行改进 [13, 22, 32]，例如李胜金等 [25] 提出了基于 ECDH 的可认证密钥协商协议等，通过实现通信双方的身份认证来抵御中间人的攻击，提高密钥交换过程的安全性。需要指出的是，以太坊上的节点通信过程虽然基于 ECDH 算法，但流程更为复杂、安全。

3.3 节点加密通信过程

以太坊上使用 RLPx 协议进行通信加密。它实现了完备的前向安全性（Perfect Forward Secrecy），也就是在每次建立连接时使用不同的密钥，即使现有的密钥泄露也不会导致之前信道上的信息被破解，主要包含两个阶段：（1）密钥交换；（2）身份认证与协议握手。

在 RLPx 协议中，每个节点都拥有自己的公钥和私钥，并且会在通信时各自生成一个临时的随机密钥对。节点的密钥交换主要采用了 ECDH 算法，通信节点分别使用自己的私钥和对方的公钥计算出一个共享的密钥。两个节点进行密钥交换的流程如下 [34]：

（1）节点 A 生成随机密钥对和随机数，用自己的私钥对节点 B 的公钥执行 ECDH 算法，将结果和随机数异或后使用随机生成的私钥对其签名，然后将随机数、签名、节点 A 的公钥、版本号打包后用节点 B 的公钥进行加密作为请求认证的握手报文进行发送；

（2）节点 B 使用自己的私钥对收到的握手报文进行解密，得到节点 A 生成的随机数、签名、公钥和版本号。节点 B 生成随机密钥对和随机数，用自己的私钥和节点 A 的公钥执行 ECDH 算法，根据得到的结果和签名推导出节点 A 的随机公钥，利用随机私钥和节点 A 的随机公钥生成共享密钥，然后将自己的临时公钥和随机数用发起者的公钥进行加密并发送。

（3）节点 A 对节点 B 的消息进行解密获得节点 B 的临时公钥和随机数，利用 ECDH 算法计算出共享密钥。经过这个阶段后，节点 A 和节点 B 都知道双方通信的共享密钥和随机数了，其中，随机数会被用来生成消息认证码来保证消息的完整性。

身份认证与协议握手步骤主要用于两个节点进行协议协商，如果通信双方协议版本不符合，通信会断开，主要过程如下：

（1）节点 A 用共享密钥加密由自己使用的 P2P 版本号、端口号、ID 等信息构成 Hello 报文，并将 Hello 报文向节点 B 发送；

（2）节点 B 使用共享密钥对 Hello 报文进行解密，也类似地用共享密钥对 Hello 报文进行加密并发送；

（3）节点 A 完成 Hello 报文的校验。如果双方都能接受对方的协议版本，双方建立通信。

4 以太坊用户交易验证

以太坊允许任意节点加入网络、允许任何用户参与交易，全部账本数据公开透明且由多方共同维护。这些有别于传统数据库的特性，使得区块链系统无法直接应用传统数据库的安全机制——完善的用户管理和存取控制，因为用户管理通常需要运行在中心化的节点上，这和区块链所强调的去中心化相矛盾。

目前，以太坊主要基于数字签名与验证来确保数字货币的所有权以及交易的不可伪造、不可否认的特性；依靠每次交易使用不同的数字证书和账户地址来保障交易的隐私性。如图 5所示，以太坊的交易数据中只包含了发送者的 ECDSA 签名，并不包含发送者的公钥和发送者的地址，因为基于 ECDSA 签名、原始交易数据和椭圆曲线参数可以恢复出发送者的公钥，然后对公钥进行 SHA3 哈希运算，即可计算出发送者的账户地址。如此设计可减少每笔交易的字节数，从而减少交易数据在存储和网络方面的开销 [31]。如果交易受到篡改，计算通过交易哈希值和签名得到的地址便是错误的，即无法通过篡改发送者签名过的交易来攻击发送者的账户。

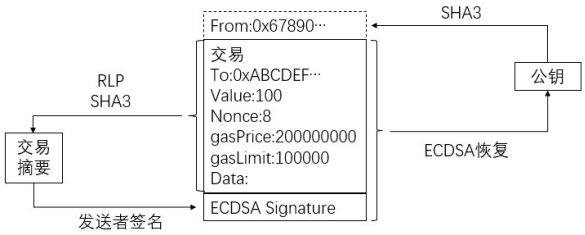

Figure 5: 以太坊签名与验证

4.1 EC 曲线离散对数问题的难解性

椭圆曲线离散对数问题 (Elliptic Curve Discrete Logarithm Problem, ECDLP) 的困难性是所有椭圆曲线密码方案安全性的基础。

ECDLP 指的是在定义于有限域 F_q 上的椭圆曲线 E 上，基点 $P \in E(F_q)$，阶为 n，点 $Q \in <P>$，寻找一个整数 $l \in [0, n-1]$ 使得 $Q = lP$，整数 l 称为 Q 的基于 P 的离散对数，表示为 $l = log_P^Q$。目前而言，解决 ECDLP 最简单的方法是穷举搜索，即连续计算一系列的点：$P, 2P, 3P, \cdots$，直到找到点 Q。该方法的时间成本在最坏情况下为 n，平均情况下为 $n/2$，当我们选择参数足够大的椭圆曲线时，穷举的计算量在实际层面上将无法实现，例如当 $n \geq 2^{80}$ 时。

自 1985 年椭圆曲线密码被提出以来，椭圆曲线离散对数问题被许多学者研究，但目前仍没有发现亚指数时间的通用算法。Darrel 等人 [6] 指出 ECDLP 同时属于 NP 问题与 co-NP 问题。多年来的实践也已证明椭圆曲线离散对数问题的难解性。

正是由于椭圆曲线具有该特性，其在密码学中应用广泛。而对于一个签名方案而言，若对于能够使用选择明文攻击的攻击者在计算能力内是不可伪造的，则称之为 GMR 安全 [6]。根据上文所述，当选择参数足够大的椭圆曲线时，穷举的计算量无法实际实现，这就说明，在用户交易验证中，攻击者即使知道公钥也难以计算出私钥，故而能够满足安全性要求的椭圆曲线数字签名算法被提出与应用。

4.2 ECDSA 数字签名生成与验证

在有限域 $GF(p)$ 上，设计一个六元组 T，表示为 $T = (p, a, b, G, n, h)$，那么可以确定一条椭圆曲线 E 和一个基点 G，六元组 T 中 a，$b \in Fp$，a 和 b 满足方程 $y^2 = x^3 + ax + b \ mod \ p$，$G = (x_G, y_G)$ 为椭圆曲线上的基点，并且基点 G 的阶 n 是一个大素数整数，T 中的 h 为余因子并且为整数，满足 $h = E(Fp)/n$。签名的双方建立起自己的密钥对 (d, Q)，有 $Q = dG$，其中 Q 为公钥，d 为私钥。

数字签名的生成算法如下 [23]：

Algorithm 1 Generating Digital Signature

Input: $T = (p, a, b, G, n, h)$, d, m
Output: (r, s)
compute $e = H(m)$
MARK
choose a random integer k *and* $k \in [1, n-1]$
compute $kG = (x_1, y_1)$
compute $r = x_1 \ mod \ n$
if $r = 0$
    jump MARK
end if
compute $s = k^{-1}(e + dr) \ mod \ n$
if $s = 0$
    jump MARK
end if
return $((r, s))$

如果计算结果有 $r = 0$ 或 $s = 0$，则表明签名结果不成功；由于随机整数 k 值是随机选取的，那么签名结果失败概率几乎可以忽略不计，最后应将签名结果 (r, s) 和消息 m 发给消息的接收方。

数字签名的验证算法如下：

Algorithm 2 Verifying Digital Signature

Input: $T = (p, a, b, G, n, h)$, d, Q, m, (r, s)
Output: *Accept/Deny the signature*
if $r \notin [1, n-1]$ *or* $r \neq [r]$
    return (”*Deny the signature*”)
else if $s \notin [1, n-1]$ *or* $s \neq [s]$
    return (”*Deny the signature*”)
else continue
end if
compute $e = H(m)$
compute $w = s^{-1} \ mod \ n$
compute $u_1 = ew \ mod \ n$ *and* $u_2 = rw \ mod \ n$
compute $X = u_1 \ G + u_2 \ Q$
if $X = \infty$
    return (”*Deny the signature*”)
end if
$x_1 <\!\!-\!\!- [X_x]$
compute $v = x_1 \ mod \ n$
if v=r
    return (”*Accept the signature*”)
else
    return (”*Deny the signature*”)

可以用 $v = r$ 作为接受签名的原因是，如果一条消息 m 的签名 (r, s) 确实由合法的签名者产生，那么 $s \equiv k^{-1}\ (e+dr)(mod\ n)$。重新整理可得：$k \equiv s^{-1}\ (e+dr) \equiv s^{-1}\ e + s^{-1}\ dr \equiv we + wrd \equiv u_1 + u_2\ d(mod\ n)$

于是 $X = u_1\ G + u_2\ Q = (u_1 + u_2\ d)G = kG$ ，故而 $v = r$ 可成为验证签名合法的条件。

4.3 签名方案的改进

签名验证过程可以通过压缩多个签名或者将多个签名的验证等式聚合来降低验证成本和提高验证效率，这正是下文中提到的聚合签名和批验证的作用。而组测试则是针对批验证中发现的错误批次进行筛选和剔除其中的无效签名。

4.3.1 **聚合签名**. 签名聚合算法能够将来自多个用户的 n 条消息聚合成一个短签名。一般情况下，聚合签名产生的签名数据（不包括消息原数据和公钥列表）具有大小固定的特性，即无论有多少原始签名，聚合后签名数据的大小总是恒定 [17]。

聚合签名可以有效降低存储空间和验证过程中网络流量成本，尤其对签名频次较低但验证频次较高的业务场景有显著效果。然而，聚合签名更侧重于压缩签名和公钥的大小，而不会提高签名的验证效率 [15]。

4.3.2 **批验证**. 在批验证思想中，n 个消息将被作为一个整体执行签名代替了逐个对每个消息执行签名，从而可以将 n 次签名运算减少到 1 次签名运算。通过将标准 ECDSA 签名的验证等式 $R = uP + vQ$ 聚合，批验证方案可以定义为 [35]：

$$\sum_{i=1}^{t} R_i = (\sum_{i=1}^{t} u_i)P + \sum_{i=1}^{t} v_i Q_i \tag{2}$$

如果计算结果相等，则这批 ECDSA 签名合法，反之这批签名中包含至少一个无效签名。ECDSA 批量验证方案可以将椭圆曲线点乘的运算数量从 2t 减少到 [2,t+1], t 代表公式中涉及到不同签名者的个数。

4.3.3 **组测试**. 在公有链中，任何节点都可以加入区块链网络，这其中也包括恶意攻击者。加入公有链的恶意节点可以使用带有伪造签名的虚假交易淹没网络，并发起拒绝服务 (DoS) 攻击以延迟合法交易服务。海量无效签名的验证占用了节点大量的计算资源，浪费了大量的时间，因此提高签名验证效率和正确识别无效签名对于区块链减轻 DoS 攻击带来的计算负担至关重要。

组测试的方法通过将错误批次中的签名进行拆分重组，并对重组的签名分别执行批验证，不断的将错误批次递归执行拆分批验证，最后可以剔除所有的无效签名。

组测试算法可用二叉树结构表示，根节点包含所有待识别的 ECDSA 签名，而其下一层的每个子节点分别包含根节点的一半签名。遵循此规律，二叉树可以被不断递归拆分，直到叶子节点中只包含一个签名或此节点包含的签名批验证结果为真 [35]。

5 总结与思考

本文的主要贡献在于以以太坊为例阐述了区块链的运作机制，并从节点与用户两个层面介绍了以太坊加密的核心技术和前沿研究。

首先，本文从区块链的起源开始，概述了区块链的建立过程及特点，重点讲解了以太坊的运作机制。第二章阐释了用于以太坊中实现 P2P 网络路由的 Kademlia 协议，详述了 P2P 网络安全性的优劣势以及研究人员针对问题提出的一系列应对机制。第三章在网络节点层面阐述了以太坊加密通信过程，介绍了 RLPx 协议与 ECDH 算法。第四章以椭圆曲线数字签名的生成、验证与方案改进为主体，介绍了以太坊的用户交易验证。最后，本文提出了以下思考。

以太坊中的网络安全，核心在于由 UDP 和 TCP 协议构成的 P2P 网络。一方面，以太坊由于其独特的链式结构和底层的 P2P 网络，在安全性方面有独特优势，黑客很难通过攻击某一个节点获得大量用户信息，从而更改全局账本。另一方面，由于其去中心的分布式架构和公有链无准入要求的特点，以太坊在安全方面也存在劣势。在 P2P 网络安全性的应对机制调研中，我们认为目前深度学习与 P2P 网络的结合仍不够深入，能动性更强的 AI for science 可能是推动深度学习与 P2P 网络深度融合的可行方案。

关于以太坊中的交易安全，我们认为，每一笔在以太坊发起的交易都会被全网广播让所有节点验证的流程虽然保证了每笔交易的安全性，但是也给用户造成很大的隐私问题。例如，针对网络层采用的泛洪法传播机制，攻击者可以采用启发式聚类法 [14] 推测出每个节点的关系及身份，导致区块链匿名化特性丧失。为保证用户权益，从密码学的角度，零知识证明可以在无需泄露数据本身情况下证明某些数据运算。环签名技术可视为一种弱化的零知识证明，它是一种特殊的群签名组成的协议。在其中，你需要证明的是，你拥有着这组群签名中的任意一个签名的签署权，但别人只知道你是成员之一，却不知道这组环签名代表的资产具体的持有者是谁。

现阶段，我们处在 Web2.0 时代，Web3.0 还处于早期阶段，以太坊正是 Web3.0 的一个组成部分。通过对前沿研究的总结梳理，本文说明了以太坊在节点加密与用户交易验证层面的安全优势，也指出了其安全性仍有较大进步空间。我们期待在未来，Web3.0 可以通过分布式存储保护数据安全、数据隐私和用户的数据所有权，让用户拥有一个更加智能化、个性化的互联网时代。

REFERENCES

[1] [n. d.]. Bitcoin: A Peer-to-Peer Electronic Cash System. *Social Science Electronic Publishing* ([n. d.]).

[2] Maria Apostolaki, Aviv Zohar, and Laurent Vanbever. 2017. Hijacking bitcoin: Routing attacks on cryptocurrencies. In *2017 IEEE symposium on security and privacy (SP)*. IEEE, 375–392.

[3] American Bankers Association et al. 1998. Working Draft: American National Standard X9. 62-1998 Public Key Cryptography for the Financial Services Industry. (1998).

[4] LM Axon and Michael Goldsmith. 2016. PB-PKI: A privacy-aware blockchain-based PKI. (2016).

[5] Xuan Chen, Kien Nguyen, and Hiroo Sekiya. 2021. An experimental study on performance of private blockchain in IoT applications. *Peer-to-Peer Networking and Applications* 14, 5 (2021), 3075–3091.

[6] Alfred Menezes Darrel Hankerson and Scott Vanstone. 2004. *Guide to Elliptic Curve Cryptography*.

[7] devp2p. 2022. devp2p. (2022). https://github.com/ethereum/devp2p/ [Online; accessed 10-Dec-2022].

[8] Whitfield Diffie, Paul C Van Oorschot, and Michael J Wiener. 1992. Authentication and authenticated key exchanges. *Designs, Codes and cryptography* 2, 2 (1992), 107–125.

[9] Yue Gao, Jinqiao Shi, Xuebin Wang, Qingfeng Tan, Can Zhao, and Zelin Yin. 2019. Topology measurement and analysis on ethereum p2p network. In *2019 IEEE Symposium on Computers and Communications (ISCC)*. IEEE, 1–7.

[10] Ethan Heilman, Alison Kendler, Aviv Zohar, and Sharon Goldberg. 2015. Eclipse attacks on {Bitcoin' s}{peer-to-peer} network. In *24th USENIX Security Symposium (USENIX Security 15)*. 129–144.

[11] Soo Hoon Maeng, Meryam Essaid, and Hong Taek Ju. 2020. Analysis of ethereum network properties and behavior of influential nodes. In *2020 21st Asia-Pacific network operations and management symposium (APNOMS)*. IEEE, 203–207.

[12] Petar Maymounkov and David Mazieres. 2002. Kademlia: A peer-to-peer information system based on the xor metric. In *International Workshop on Peer-to-Peer Systems*. Springer, 53–65.

[13] Nissa Mehibel and M'hamed Hamadouche. 2017. A new approach of elliptic curve Diffie-Hellman key exchange. In *2017 5th International Conference on Electrical Engineering-Boumerdes (ICEE-B)*. IEEE, 1–6.

[14] Sarah Meiklejohn, Marjori Pomarole, Grant Jordan, Kirill Levchenko, Damon McCoy, Geoffrey M. Voelker, and Stefan Savage. 2016. A Fistful of Bitcoins: Characterizing Payments among Men with No Names. *Commun. ACM* (mar 2016), 86–93.

[15] Mehibel Nissa and Hamadouche M' hamed. 2020. A new enhancement of elliptic curve digital signature algorithm. *Journal of Discrete Mathematical Sciences and Cryptography* (2020).

[16] Lihua Zhang, Yu Cao, Ganzhe Zhang, Yang Huang, and Chen Zheng. 2021. A blockchain-based microgrid data disaster backup scheme in edge computing. *Security and Communication Networks* 2021 (2021).

[17] Y. Zhao. 2019. Practical Aggregate Signature from General Elliptic Curves, and Applications to Blockchain. In *the 2019 ACM Asia Conference*.

[18] Guy Zyskind, Oz Nathan, et al. 2015. Decentralizing privacy: Using blockchain to protect personal data. In *2015 IEEE Security and Privacy Workshops*. IEEE, 180–184.

[19] 张龙. 2022. 基于深度学习的流量分类与异常检测研究. Ph.D. Dissertation. 天津理工大学.

[20] 徐卫克. 2021. 基于优化 Kademlia 协议的 P2P 网络资源发现算法研究. 网络安全技术与应用 (2021).

[21] 斯雪明, 徐蜜雪, and 苑超. 2018. 区块链安全研究综述. 密码学报 5, 5 (2018), 458–469.

[22] 曹阳, 郝玉洁, and 洪歧. 2012. 一种基于 ECDLP 有身份认证的 ECDH 密钥协商方案. 重庆邮电大学学报: 自然科学版 24, 1 (2012), 118–120.

[23] 朱紫钊. [n. d.]. 基于椭圆曲线的数字签名研究. Ph.D. Dissertation. 暨南大学.

[24] 李磊. [n. d.]. *MazeKad - Maze* 中基于 *Kademlia* 协议的 *DHT* 系统实现及优化. MazeKad - Maze 中基于 Kademlia 协议的 DHT 系统实现及优化.

[25] 李胜金, 张昌宏, and 周大伟. 2011. 一种基于 ECDH 的可认证密钥协商协议. 信息安全与通信保密 9, 7 (2011), 70–72.

[26] 林宏刚, 张运理, 郭楠馨, and 陈麟. 2022. 基于图神经网络的 P2P 僵尸网络检测方法. (2022).

[27] 沈鑫, 裴庆祺, and 刘雪峰. 2016. 区块链技术综述. 网络与信息安全学报 2, 11 (2016), 11–20.

[28] 祝跃飞，张亚娟著. 2006. 椭圆曲线公钥密码导引. 北京：科学出版社.

[29] 程希. [n. d.]. 物理位置与兴趣相结合的 *P2P* 搜索技术研究. Ph.D. Dissertation. 南京理工大学.

[30] 赵昊, 舒辉, 康绯, and 邢颖. 2021. 基于智能合约的高对抗性僵尸网络研究. 网络与信息安全学报 7, 4 (2021), 30–41.

[31] 邵奇峰, 金澈清, 张召, 钱卫宁, and 周傲英. 2018. 区块链技术: 架构及进展. 计算机学报 41, 5 (2018), 20.

[32] 邵晓博. 2010. 椭圆曲线密码体制中密钥协商方案改进的研究. 计算机安全 2 (2010), 23–25.

[33] 邹福泰, 谭越, 王林, 蒋永康, et al. 2021. 基于生成对抗网络的僵尸网络检测. 通信学报 42, 7 (2021), 95–106.

[34] 郑子彬, 陈伟利, and 郑沛霖. 2021. 区块链原理与技术. (2021).

[35] 金川杰. 2021. 面向区块链的高效数字签名算法研究. Ph.D. Dissertation. 电子科技大学.

[36] 马小力. [n. d.]. 基于改进的 *Kademlia* 算法的 *P2PSIP* 网络电话系统的设计与研究. Ph.D. Dissertation. 电子科技大学.

[37] 高镇, 张东彬, and 田潇. 2022. 基于以太坊状态数据库的攻击与防御方案. 网络与信息安全学报 8, 2 (2022), 64–72.